Smart threat response Assistant leveraging standard operating procedures (SOP) and large language models(LLM)

ABSTRACT

Modern organizations face increasing cybersecurity threats such as phishing, ransomware, insider attacks, and unauthorized access attempts. Security teams often rely on Standard Operating Procedures (SOPs) to respond to incidents consistently and in compliance with organizational policies. However, during high-pressure situations, analysts may struggle to quickly identify the correct procedures, leading to delayed responses and human error.

This project proposes an AI-assisted cybersecurity incident response framework that combines Retrieval-Augmented Generation (RAG) with Large Language Models (LLMs) to provide SOP-aware incident handling guidance. Instead of relying on fully autonomous response execution, the system acts as an intelligent decision-support assistant for security analysts. The framework retrieves relevant SOP sections from a centralized SOP repository and uses an LLM to generate contextual recommendations, incident summaries, severity analysis, and step-by-step response guidance.

The proposed system focuses on explainability, auditability, and human-in-the-loop security operations. Every recommendation generated by the LLM is accompanied by references to the corresponding SOP sections used during retrieval. A confidence-scoring mechanism helps analysts identify uncertain recommendations that require additional review. The framework also maintains detailed audit logs containing alert information, retrieved SOP references, analyst actions, and timestamps for compliance and forensic purposes.

The system uses simulated cybersecurity alerts and attack scenarios to demonstrate incident triage and response workflows. By integrating RAG-based knowledge retrieval with SOP-guided reasoning, the project aims to reduce response time, improve consistency in incident handling, and minimize human error while ensuring that analysts remain in control of all critical decisions.

INTRODUCTION

Cybersecurity incidents are becoming increasingly sophisticated and frequent in modern enterprise environments. Organizations depend on Security Operations Centers (SOCs) and incident response teams to detect, analyze, and mitigate threats before they cause significant damage. To ensure consistency and compliance, organizations define Standard Operating Procedures (SOPs) that guide analysts during incident handling.

Traditional incident response processes are largely manual and depend heavily on analyst experience and decision-making under pressure. Existing automated solutions often rely on static rule-based workflows that struggle to adapt to new or evolving threats. At the same time, fully autonomous AI-driven response systems introduce security and reliability concerns due to hallucinations, incorrect recommendations, and lack of transparency.

To address these challenges, this project proposes an SOP-guided cybersecurity assistant using Retrieval-Augmented Generation (RAG) and Large Language Models (LLMs). The system retrieves relevant SOP content based on incoming incident alerts and uses the LLM to generate contextual, explainable recommendations for analysts.

The proposed framework emphasizes:

- Human-in-the-loop decision making
- SOP-grounded AI reasoning
- Explainable recommendations
- Auditability and traceability
- Secure handling of incident data

Rather than replacing human analysts, the system acts as an intelligent assistant that improves response consistency and reduces incident handling delays.

PROBLEM STATEMENT

Enterprise incident response processes often suffer from delayed decision-making, inconsistent handling procedures, and dependence on individual analyst expertise. During active security incidents, analysts must quickly identify appropriate SOPs, assess incident severity, and determine suitable response actions. This process can become time-consuming and error-prone, especially when dealing with large volumes of alerts.

Existing automated response systems typically rely on predefined playbooks and rigid workflows that cannot easily adapt to evolving attack patterns. On the other hand, fully autonomous AI systems may produce unreliable or unsafe recommendations due to hallucinations or lack of contextual grounding.

Furthermore, many existing systems lack:

- SOP-aware contextual guidance
- Explainable AI-generated recommendations
- Traceable audit logs linked to procedures
- Human validation mechanisms
- Efficient retrieval of relevant security procedures

Therefore, there is a need for a secure and explainable AI-assisted framework that uses Retrieval-Augmented Generation (RAG) to retrieve relevant SOP knowledge and assist analysts during cybersecurity incident response.

OBJECTIVES OF THE PROJECT

1. To design a cybersecurity incident response assistant using Retrieval-Augmented Generation (RAG) and Large Language Models (LLMs).

2. To develop an SOP retrieval mechanism that identifies relevant procedures based on incoming security alerts.

3. To generate contextual and explainable incident response recommendations using LLMs.

4. To provide step-by-step guidance for incident triage, containment, and remediation aligned with organizational SOPs.

5. To implement a confidence-scoring mechanism for identifying uncertain recommendations.

LITERATURE SURVEY

S.No.	Paper Name & Author(s)	Method / Approach	Strengths	Limitations / Gaps
1	When LLMs meet cybersecurity: a systematic literature review – Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., Zhu, H., & Meng, D. (2025)	Systematic literature review of LLM applications in cybersecurity	Comprehensive coverage of LLM use cases in cybersecurity	No focus on SOP integration or real-time incident response automation
2	Harnessing the power of language models in cybersecurity: A comprehensive review – Kaur, R., Klobučar, T., & Gabrijelčič, D. (2025)	Comprehensive review of language models in cybersecurity	Highlights potential of LLMs for security operations	Lacks practical implementation frameworks; no SOP-guided approach
3	LLMs for Cybersecurity in the Big Data Era: A Comprehensive Review – Karras, A., Theodorakopoulos, L., Karras, C., Theodoropoulou, A., Kalliampakou, I., & Kalogeratos, G. (2025)	Review of LLM applications, challenges, and future directions in big data cybersecurity	Identifies scalability and big data challenges	No focus on policy compliance or procedural adherence
4	Advances in AI for cybersecurity – Ferrag, M. A., et al. (2024)	Overview of AI advances in cybersecurity	Summarizes key AI	Does not address LLM-SOP integration or

PROPOSED METHODOLOGY

Step 1: SOP Collection and Processing

- Collect cybersecurity SOP documents in PDF, DOCX, or TXT format.
- Extract and preprocess text content from SOPs.
- Split SOP content into smaller searchable chunks.

Step 2: Vector Embedding and Storage

- Convert SOP chunks into vector embeddings using embedding models.
- Store embeddings in a vector database for efficient retrieval.

Step 3: Alert Simulation

- Generate simulated cybersecurity alerts such as:
    - phishing attacks
    - malware detection
    - brute-force attempts
    - unauthorized access

Step 4: Retrieval-Augmented Generation (RAG)

- User submits an incident alert.
- System retrieves relevant SOP sections from the vector database.
- Retrieved SOP context is provided to the LLM.

Step 5: LLM-Based Recommendation

The LLM generates:

- Incident summary
- Severity level
- Recommended actions
- SOP references
- Analyst guidance

Step 6: Confidence Scoring

- Assign confidence levels:
    - Low
    - Medium
    - High
- Low-confidence outputs require analyst review.

Step 7: Audit Logging

- Store:
    - incident details
    - retrieved SOP references
    - generated recommendations
    - analyst decisions
    - timestamps

Step 8: Dashboard Interface

- Provide a web dashboard displaying:
    - alerts
    - recommendations
    - SOP references
    - audit logs

REQUIREMENTS

Functional Requirements

1. SOP document upload and parsing.
2. SOP chunking and embedding generation.
3. Vector database storage for RAG retrieval.
4. Simulated alert ingestion.
5. Retrieval of relevant SOP sections.
6. LLM-based recommendation generation.
7. Confidence score generation.
8. Human approval/rejection workflow.
9. Audit trail generation.
10. Dashboard visualization.

Non-Functional Requirements

1. Secure handling of incident data.
2. Explainable AI recommendations.
3. Role-based access for analysts.
4. Low response latency for recommendations.
5. Scalable SOP storage architecture.
6. Reliable logging and traceability.
7. Easy integration with future SOC tools.

TOOLS AND TECHNOLOGIES

Frontend

- React / HTML / CSS

Backend

- Python
- Flask / FastAPI

AI & NLP

- OpenAI API / LLaMA
- LangChain

RAG Components

- Sentence Transformers
- FAISS / ChromaDB

Database

- MongoDB / PostgreSQL

Security & Logging

- JWT Authentication
- SHA-256 log hashing

EXPECTED OUTCOMES

1. Working prototype of an SOP-guided cybersecurity assistant.
2. Efficient retrieval of SOP information using RAG.
3. Context-aware incident response recommendations.
4. Improved consistency in cybersecurity incident handling.
5. Explainable AI-generated guidance with SOP references.
6. Reduced analyst response time.
7. Detailed audit logs for compliance and forensic review.
8. Human-controlled AI-assisted incident response workflow.

SUMMARY

This project presents an SOP-guided cybersecurity incident response assistant using Retrieval-Augmented Generation (RAG) and Large Language Models (LLMs). The framework focuses on assisting security analysts by retrieving relevant SOP knowledge and generating explainable recommendations for incident handling.

Unlike fully autonomous systems, the proposed framework follows a human-in-the-loop approach where analysts remain responsible for validating all critical actions. By combining RAG-based retrieval, LLM reasoning, explainable recommendations, and audit logging, the system improves response consistency, reduces delays, and strengthens operational security practices.

The project demonstrates how AI can be safely integrated into cybersecurity workflows while maintaining transparency, procedural compliance, and analyst control.

1. Ouyang, L., et al. “Training language models to follow instructions with human feedback.” arXiv, 2022.
2. Lewis, P., et al. “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks.” NeurIPS, 2020.
3. Touvron, H., et al. “LLaMA: Open and Efficient Foundation Language Models.” 2023.
4. Roziere, B., et al. “Code Llama: Open Foundation Models for Code.” 2023.
5. Zhang, J., et al. “When LLMs meet cybersecurity: a systematic literature review.” 2025.
6. Ferrag, M. A., et al. “Advances in AI for cybersecurity.” 2024.
7. LangChain Documentation – Retrieval-Augmented Generation Framework.
8. FAISS Documentation – Facebook AI Similarity Search.